

CREATORNIVO

Мастер-досье проекта, полный аудит и дорожная карта

Сводка решений, реализованных исправлений, рисков, предложений и следующих задач

Версия 1.0 | 4 июля 2026

Назначение документа

Сохранить в одном месте историю ключевых решений по Creatornivo, результаты полного аудита Codex, предложения владельца проекта, фактический статус Sandbox-платежей, перечень Live-блокеров и последовательность дальнейшей работы. Документ не содержит секретных ключей и не заменяет консультацию юриста или бухгалтера.

Внутренний рабочий документ. Не публиковать как юридическое заключение.

Содержание

1. Как читать документ и текущий вердикт
2. Фактический профиль проекта и принятые решения владельца
3. Текущее состояние продукта
4. Безопасные лимиты генераций и usage accounting
5. Paddle Sandbox: реализованная платежная цепочка
6. Early Access и ценовая модель
7. Полный предрелизный аудит Codex
8. Публичные маршруты и страницы
9. Маркетинговые тексты и доверие
10. Terms, Privacy и Refund Policy
11. Mobile header, responsive и тема System
12. Auth, аккаунт и персональные данные
13. Операционная безопасность и инфраструктура
14. Resources / Guides: план раздела статей
15. Приоритетная дорожная карта до Early Access и Paddle Live
16. Контрольные чек-листы
17. Архив следующих заданий для Codex
18. Журнал решений и спорные вопросы

Обозначения статусов

[DONE] уже реализовано и проверено; [BLOCKER] блокирует реальные платежи или создаёт высокий риск; [NEXT] следующая рекомендуемая задача; [REVIEW] требует решения владельца или специалиста; [INFO] справочная информация.

1. Как читать документ и текущий вердикт

Текущий вердикт

Creatornivo уже имеет работоспособную техническую основу для ограниченного Sandbox Early Access. Регистрация, генерационный интерфейс, серверные лимиты, Paddle Sandbox checkout, webhook-активация Pro, Customer Portal, обновление способа оплаты и отмена продления протестированы. Для Paddle Live проект пока не готов из-за отсутствия refund/adjustment/chargeback lifecycle, неполного account/privacy workflow, отсутствия подтверждённого backup/restore и мониторинга, а также непроверенной Live-конфигурации.

[DONE] Sandbox checkout и Pro-активация работают.

[DONE] Generation limits и idempotency переработаны.

[DONE] Mobile header и публичный сору прошли полный локальный аудит.

[BLOCKER] Refund/adjustment/chargeback webhook logic отсутствует.

[BLOCKER] Paddle Live credentials, domain approval, Live webhook и Live Price IDs не проверены.

[NEXT] Password reset, rate limiting auth, deletion/export workflow ещё отсутствуют.

[REVIEW] Terms, Privacy и Refund Policy фактически улучшены, но не являются юридическим заключением.

- **Early Access Beta можно считать технически возможным только в Sandbox или в закрытом тестовом режиме.** Перед реальными оплатами должен быть закрыт денежный lifecycle возвратов и определён операционный процесс поддержки.
- **Paddle Live нельзя включать только заменой ключей.** Sandbox и Live полностью разделены по продуктам, ценам, API keys, client tokens, webhook secrets и покупателям.
- **Этот документ фиксирует состояние на дату версии.** После крупных изменений его следует обновлять новой редакцией, а старую хранить как журнал решений.

2. Фактический профиль проекта и принятые решения владельца

Параметр	Зафиксированное решение
Название	Creatornivo
Домен	https://www.creatornivo.com
Поддержка	support@creatornivo.com
Оператор	Независимый software-проект, управляемый физическим лицом в Украине
Юридический статус	Зарегистрированной компании, LLC, Inc. или ФОП на текущем этапе нет
Платежи	Paddle как Merchant of Record; продажи не отключать
Free	5 генераций за UTC-день; до 10 сохранённых prompts; 8 core templates; GPT-4o mini
Pro	100 генераций за UTC-месяц; unlimited saved prompts; все шаблоны; GPT-4o; export .md/.txt; email support
Стандартная цена Pro	\$9.90/month
Early Access founding price	\$4.90/month, доступна ограниченное время без выдуманного счётчика мест
Контент	Не использовать fake testimonials, fake ratings, fake counters

Параметр	Зафиксированное решение
	и недоказуемые обещания
Статьи	Позднее добавить Resources / Guides по тематике реальных функций продукта
Публикация	Сначала закрыть критические риски, затем переходить в Paddle Live

Принцип честного позиционирования

Не скрывать, что это ранний независимый продукт. Не изображать несуществующую компанию, команду, офис или американскую юрисдикцию. Доверие должно строиться на рабочем продукте, прозрачных лимитах, реальной поддержке и честном описании Beta/Early Access.

3. Текущее состояние продукта

Область	Состояние	Комментарий
Главная и Pricing	Работают	Публичный сору очищен от fake scarcity и недоказуемых обещаний.
Регистрация / вход	Работают	Credentials auth; password hash bcrypt; нет reset и email verification.
Dashboard	Работает	Показывает план и серверный usage.
Templates	Работают	15 templates, 8 Free.
Generate	Работает при наличии OpenAI API key	Без ключа возвращается 503 generation_disabled до reservation.
Library	Работает	Сохранение, поиск, просмотр, экспорт; удаления saved items нет.
Settings	Работает	Тема, профиль, subscription status, Customer Portal actions.
Onboarding tour	Работает	Исправлено позиционирование роуп и мобильная видимость.
Paddle Sandbox	Работает	Checkout, webhook, Pro, receipt, portal, cancel at period end.
Stripe fallback	Legacy/нежелательно	Нужно явно зафиксировать провайдера перед Live.
Legal pages	Фактически улучшены	Нужна внешняя юридическая проверка.
Error/loading/404	Framework default	Брендируемые состояния отсутствуют.
Resources/Guides	Отсутствует	Есть согласованный план архитектуры и тем.

Фактическое доказательство платежной цепочки

В Sandbox успешно выполнена покупка Pro Monthly за \$4.90 с VAT, получен Paddle receipt, webhook перевёл пользователя с Free на Pro, Customer Portal показал активную подписку, Update payment method и Cancel subscription работали. После отмены продления сайт сохранил Pro до конца оплаченного периода.

4. Безопасные лимиты генераций и usage accounting

- **Стабильный requestId.** Клиент создаёт один UUID v4 на одну пользовательскую попытку и хранит его устойчиво; network retry использует тот же UUID.
- **Защита двойного клика.** Синхронный inFlightRef не позволяет двум быстрым кликам отправить два fetch до React re-render.
- **Сервер требует requestId.** Fallback randomUUID на сервере удалён; отсутствие или неверный UUID возвращает HTTP 400.
- **Idempotency по пользователю.** Уникальность GenerationReservation составная: userId + requestId.
- **Duplicate request.** Active duplicate возвращает generation_in_progress; completed - generation_already_completed; повторный OpenAI вызов не выполняется.
- **Reservation до провайдера.** reserved создаётся до OpenAI; startedAt ставится непосредственно перед вызовом.
- **Quota semantics.** Ошибка до startedAt не расходует квоту; ошибка или disconnect после startedAt расходует одну генерацию.
- **Expired reservation.** Истёкшая reservation перестаёт блокировать concurrency; started reservation продолжает учитываться в квоте.

- **Usage source of truth.** UI не увеличивает счётчик локально; после завершения запроса перечитывает серверный /api/ai/usage.
- **Demo fallback удалён.** Отсутствующий OPENAI_API_KEY не создаёт Generation/Reservation и возвращает generation_disabled.

Free: 5 generations per UTC day
 Pro: 100 generations per UTC month
 Counted usage: status = completed OR startedAt IS NOT NULL
 Not counted: reserved without startedAt; failed before startedAt; validation/config/rate-limit rejection

Проверка	Результат на момент внедрения
Prisma validate / generate	Успешно
Generation-limit tests	46/46 на соответствующем этапе; затем общий набор расширился
Все релевантные tests	До 59/59, затем интегрированы в общий набор
PostgreSQL Serializable	Нужна реальная проверка на test/Preview PostgreSQL
Production build	Код проходил TypeScript; локально неоднократно блокировался Google Fonts/Windows environment

5. Paddle Sandbox: реализованная платежная цепочка

5.1 Что настроено и проверено

1. Авторизованный пользователь вызывает POST /api/paddle/checkout без передачи client-controlled userId, items или Price ID.
2. Сервер выбирает Early Access или standard Price ID из server configuration.
3. Создаётся PaddleCheckoutIntent, связанный с User; сервер создаёт Paddle Transaction и сохраняет transactionId.
4. Клиент открывает Paddle.Checkout.open({ transactionId, customer: { email } }).
5. Оплата в Sandbox проходит; Paddle отправляет receipt на billing email checkout.
6. Signed webhook связывает transaction/subscription с PaddleCheckoutIntent и User.
7. После subscription activation сервер переводит User.plan в Pro.
8. Settings показывает активную подписку и Customer Portal actions.
9. Update payment method открывает отдельную Paddle форму.
10. Cancel subscription планирует отмену в конце периода; Pro сохраняется до даты окончания.

Компонент	Статус
PADDLE_API_KEY (Sandbox)	Настроен и проверен
NEXT_PUBLIC_PADDLE_CLIENT_TOKEN	Настроен; checkout открывается
PADDLE_WEBHOOK_SECRET	Настроен; signed webhook обрабатывается
Default payment link	Настроен после ошибки transaction_default_checkout_url_not_set
Early Access Price ID	Существует и выбирается сервером
Customer email prefix	Реализован; email не используется для ownership
Customer Portal	Update payment method и Cancel работают
Cancellation at period end	Проверена; plan остаётся Pro до конца периода
Refund/chargeback lifecycle	Не реализован - главный Live blocker

Почему чек мог уйти на другой email

До исправления Paddle Checkout не получал customer.email и отправлял receipt на адрес, введённый покупателем. Теперь email текущей сессии подставляется заранее. При этом безопасная привязка покупки остаётся через PaddleCheckoutIntent и transactionId, а не через email.

Обычная отмена и возврат - разные процессы

Cancel subscription прекращает будущие списания и сохраняет доступ до конца оплаченного периода. Возврат текущего платежа оформляется отдельно через поддержку/Paddle и adjustments. Немедленная отмена - административная операция, а не обязательная self-service кнопка пользователя.

6. Early Access и ценовая модель

Элемент	Правило
Standard price	\$9.90/month
Founding price	\$4.90/month
Когда показывать \$4.90	Когда настроен существующий

Элемент	Правило
	PADDLE_EARLY_ACCESS_PRICE_ID
Fallback	\$9.90, если Early Access Price ID отсутствует
Discount percent	50, а не ошибочные 90
Разрешённый текст	Early Access founding price - available for a limited time.
Запрещённый текст	first 50 users; 50 spots left; claim your spot; fake countdown; fake counter
Checkout	Price ID выбирается сервером; UI должен совпадать с фактической ценой Paddle
CTA guest	Sign in to get Pro - \$4.90/mo
CTA Free user	Get Pro - \$4.90/mo

Причина временного исчезновения \$4.90

Early Access availability ошибочно зависела от устаревшего spotsRemaining > 0. После удаления fake counter isAvailable становился false. Исправление отвязало availability от выдуманного количества мест и восстановило \$4.90 при наличии реального Early Access Price ID.

7. Полный предрелизный аудит Codex

7.1 Риски по уровням

Уровень	Проблема	Комментарий
CRITICAL	Refund, adjustment, chargeback webhooks отсутствуют	Главный денежный Live blocker.
CRITICAL	Нет подтверждённого backup/restore процесса	Dump создан вручную, но нужен регулярный процесс и restore drill.
CRITICAL	Paddle Live credentials/domain/webhook/Price IDs не проверены	Sandbox не доказывает Live readiness.
CRITICAL	Нет документированного account deletion/data request процесса	Privacy operational blocker.
CRITICAL	Production build не завершался в локальной среде	Нужен успешный CI/Vercel build.
HIGH	Нет password reset/change password	Пользователь может потерять доступ.
HIGH	Нет email verification	Риск неверных/чужих адресов.
HIGH	Нет login/register rate limiting	Риск brute force/abuse.
HIGH	Нет production error monitoring/webhook alerts	Сбои могут остаться незамеченными.
HIGH	Нет self-service account deletion/data export	Можно временно сделать verified support workflow.
HIGH	Support mailbox deliverability не проверена	Нужно send/receive/spam/deliverability test.
HIGH	Legal governing law/liability/indemnity/withdrawal требуют специалиста	Тексты улучшены, но owner/legal review обязателен.
HIGH	Нет глобального OpenAI spend limit	Per-user quotas не ограничивают общий бюджет.
MEDIUM	Нет явного Paddle cancel UI state	После scheduled cancellation кнопку лучше заменить на manage/resume.
MEDIUM	Нет branded error/loading/not-found	UX и доверие.
MEDIUM	Формы: нет visibility/max length/network handling	Auth UX hardening.
MEDIUM	Email не нормализуется	Trim/lowercase и unique behavior.
LOW	README шаблонный	Внутренняя документация.
LOW	Resources/Guides отсутствуют	Не блокирует продажи.
LOW	Deprecated middleware convention	Перевести на проху в отдельной задаче.

8. Публичные маршруты и страницы

Route	Доступ	Назначение	Ключевой риск
/	Public	Product, templates, pricing, registration	Copy corrected; mobile/visual review.
/pricing	Public/session-aware	Free signup, Paddle checkout,	Live environment not verified.

Route	Доступ	Назначение	Ключевой риск
		Settings	
/login	Public	Credentials login	No reset, visibility, auth rate limit.
/register	Public	Account creation	No email verification/rate limit/max lengths.
/terms	Public	Terms of Service	Owner/legal review required.
/privacy	Public	Privacy Policy	Retention/transfers/DSR process.
/refund-policy	Public	Refund request instructions	Automation absent; critical for Live.
/dashboard	Protected	Account overview	Responsive long text fixed.
/templates	Protected	Browse templates	Copy corrected.
/generate	Protected	AI generation	Server quota works; global spend cap absent.
/library	Protected	Saved content	No saved-item deletion.
/library/[id]	Protected	Copy/export/regenerate	No deletion.
/settings	Protected	Theme/profile/subscription	No password/account/data controls.
/admin	Admin	Internal overview	Coming-soon analytics; access protected.
/admin/templates/...	Admin	Template CRUD	Admin protected.
Onboarding overlay	Protected overlay	Six-step tour	Mobile positioning fixed.
404/loading/error	Framework default	Error states	No branded states.
/settings?checkout=success	Protected state	Pending/active post-checkout	Post-checkout logic fixed.
Checkout cancel	Paddle overlay close	Return without purchase	No dedicated message.

9. Маркетинговые тексты и доверие

9.1 Удалённые или заменённые утверждения

Удалено/заменено	Почему	Безопасная альтернатива
Ship content 10x faster	Недоказуемая цифра	Create content faster with reusable AI workflows
proven AI prompts	Нет доказательной базы	structured / reusable prompts
battle-tested prompts	Нет подтверждённых тестов	structured templates
publish-ready copy	AI output требует проверки	editable AI-generated draft
Under a minute / Generate in seconds	Нет гарантированного SLA	real-time streaming / generate and review
Fake Sarah/Acme testimonial	Вымышленный social proof	Product feature explanation
first 50 users / spots left	Глобальное место не резервировалось честно	available for a limited time
Secure checkout	Слишком широкое обещание	Checkout powered by Paddle
Priority support	Фактически email support	Email support
Unlock unlimited power	Pro не unlimited generations	100 generations per month
GPT-4o priority models	Priority не подтверждён	GPT-4o generation

- **Сохранённые подтверждённые утверждения:** 15 templates; 8 Free; Free 5/day и 10 saved; Pro 100/month и unlimited saved; GPT-4o mini/GPT-4o; .md/.txt export; streaming; Paddle Merchant of Record; email support.
- **Главный принцип:** не использовать слово secure как абсолютную гарантию, не обещать скорость, экономию часов, конверсию или результаты без измерений.
- **Early Access:** ценность строится на founding price, а не на выдуманном количестве мест.

10. Terms, Privacy и Refund Policy

10.1 Terms of Service

- Оператор описан как независимый проект физического лица в Украине.
- Удалены Delaware, officers, directors, employees и впечатление несуществующей корпорации.
- Удалены OAuth/team/enterprise claims, которых нет.
- Платёжные статусы и cancellation приведены к Paddle behavior.
- Сохранены обязательные consumer rights.
- Текущая формулировка governing law: laws of Ukraine / competent courts of Ukraine - требует юридической проверки.
- Требуют решения владельца/юриста: liability cap \$100, indemnification, возраст 16+, withdrawal rights для digital service.

10.2 Privacy Policy

- Фактически хранятся optional name, email, password hash, session/auth data, prompts, generated results, model/token usage, generation reservations, saved prompts, Paddle identifiers, onboarding completion.
- Theme и часть onboarding state могут храниться в localStorage.
- Удалены несуществующий avatar UI, Google/GitHub OAuth, feature analytics и неподтверждённый полный IP/device logging.
- Не заявляется наличие SCC/DPA без подтверждения.
- Account deletion и personal-data export пока доступны только через support; готового endpoint/admin workflow нет.
- Нужно документировать retention и backup periods поставщиков.
- Запросы GDPR/DSR создают реальную операционную обязанность отвечать и идентифицировать заявителя.

10.3 Refund Policy

- Сохранена 14-day guarantee как owner-sensitive обязательство.
- Удалено обещание автоматического cancel/downgrade после approved refund.
- Указано, что refund проводится Paddle, а доступ меняется отдельно после подтверждения.
- Убрано обещание review за 3-5 дней и привязка eligibility к billing email.
- Убраны недостижимые/непроверяемые usage thresholds, если сервер не хранит соответствующий показатель.
- Главный разрыв: код не обрабатывает adjustment.created/updated, approved/rejected, full/partial refund, chargeback/dispute и adjustment ID.

Юридическая оговорка

Фактические исправления снижают риск ложных заявлений, но документ не подтверждает юридическую корректность Terms, Privacy или Refund Policy. До реальных платежей желательно получить точечную проверку украинского юриста по применимому праву, consumer withdrawal, liability, privacy requests и налоговому статусу.

11. Mobile header, responsive и тема System

11.1 Что было сломано

- На узком экране navigation не помещалась, Sign out переносился, banner и основной контент выходили за viewport.
- Theme control занимал слишком много места.
- Отсутствовало компактное mobile menu для guest/auth состояний.

11.2 Реализованный mobile header

- На ширине меньше lg: логотип, компактная theme-кнопка, burger.
- Guest menu: Product, How it works, Pricing, Sign in, Get started.
- Auth menu: Product, How it works, Pricing, Dashboard, Account, Sign out.
- Escape и click on backdrop закрывают меню.
- Body scroll блокируется, первый пункт получает focus.
- Добавлены aria-expanded, aria-controls, aria-label и focus rings.
- Menu ограничено 100dvh и прокручивается.
- Footer переносит legal links; sidebar ограничен viewport; protected main получает min-w-0.
- Длинные имя/email безопасно переносятся; Early Access banner допускает перенос.

Что означает System

System - use device setting. В этом режиме сайт следует системной теме через prefers-color-scheme: если Windows/телефон использует dark mode, сайт становится тёмным; при light mode - светлым. Выбор хранится в localStorage. На mobile control циклически переключает Light -> Dark -> System.

Размер/сценарий	Что проверить вручную
320x568	Нет horizontal scroll; burger и СТА видимы.
375x667 / 390x844	Menu помещается, banner переносится.
412x915	Auth menu, длинный email, Settings.
768x1024	Переход tablet/desktop без наложений.
Zoom 125%	Header, onboarding popup, Pricing.
Guest	Sign in/Get started, закрытие по Escape/backdrop.
Authenticated	Dashboard/Account/Sign out, session не меняется.
Theme	Light, Dark, System; persistence after refresh.

12. Auth, аккаунт и персональные данные

Функция	Состояние	Приоритет
Email/password login	Есть	-
Password min 8	Есть	-
Duplicate email 409	Есть	-
Loading/disabled submit	Есть	-
Safe internal callback URL	Есть	-
Forgot/reset password	Нет	Высокий

Функция	Состояние	Приоритет
Change password	Нет	Высокий
Email verification	Нет	Высокий для публичной beta
Password visibility	Нет	Средний
Account deletion	Нет; support text	Критический privacy operation
Personal-data export	Нет; content export не равен DSR	Критический/High
Login/register rate limiting	Нет	Высокий
Input max lengths	Нет	Средний
Email trim/lowercase	Нет	Средний
Network-error handling forms	Неполное	Средний
Delete saved prompts/history	Нет	High privacy UX

13. Операционная безопасность и инфраструктура

Область	Текущее состояние	Минимум перед Live
Database backup	Ручной pg_dump создан	Регулярный schedule + offsite copy + restore drill
Supabase backups	Free plan без scheduled backups	Собственный процесс обязателен
RLS/Data API	Data API отключён; приложение использует Prisma	Проверять после схемных изменений
Webhook security	HMAC/raw body/timing-safe/event id есть	Timestamp freshness и alerting желательно
Error monitoring	Нет	Server/webhook alerts без утечки prompts
OpenAI spend	Per-user quota есть	Daily/monthly global circuit breaker/budget alert
Auth abuse	Generation защищена; auth нет	IP/account rate limit
Secrets	Vercel env; раскрытый ключ был отозван	Rotation runbook; не показывать в screenshots
Canonical hostname	www, apex 308 для GET/HEAD	Проверить Vercel domains/callbacks
Support mailbox	Создан	Тест send/receive/reply/spam/deliverability
Production build	Локально мешали EPERM/Google Fonts	CI/Vercel Ready обязателен
Next.js middleware	Deprecated convention warning	Отдельно перейти на проху
Legacy Stripe	Может включиться при неполной Paddle config	Перед Live явно зафиксировать Paddle

Бэкап, который уже был сделан

С помощью PostgreSQL 18 pg_dump был создан custom-format dump Supabase public schema. pg_restore --list подтвердил читаемый архив и наличие ключевых таблиц. Это хороший разовый снимок, но не заменяет регулярный backup/restore process.

14. Resources / Guides: план раздела статей

- /resources - статический индекс.
- /resources/[slug] - Server Components, typed local content records на первом этапе без CMS.
- SEO: generateStaticParams, generateMetadata, canonical, sitemap integration, Article JSON-LD только с реальным owner-approved author/byline.
- Поля: title, description, category, slug, publishedAt, updatedAt, reviewedByOwner.
- Перелинковка: templates, generate, library, pricing.
- Качество: каждая статья проходит ручную редакторскую проверку; без fake stats и обещаний результатов.

Категории
AI Prompting
Social Media Content
Email Marketing
SEO & Blogging
Video Scripts

Категории
Content Workflows
Creator Productivity

11. How to turn a rough idea into an editable AI draft
12. Building a reusable LinkedIn post workflow
13. Structuring an X thread with a template
14. Drafting a newsletter from a content brief
15. Writing a cold-email first draft responsibly
16. Creating a blog outline with structured inputs
17. Drafting SEO titles and meta descriptions
18. Planning a YouTube script with reusable sections
19. Creating short-form video script drafts
20. Drafting landing-page sections without fake social proof
21. Keeping tone consistent across projects
22. Reviewing AI-generated content before publishing
23. Saving and organizing useful prompt outputs
24. Free versus Pro workflows in Creatornivo
25. Exporting reviewed content to Markdown and text

Приоритет Resources

Раздел полезен для доверия, onboarding и SEO, но не должен отвлекать от refund lifecycle, auth recovery, privacy operations, backups и Paddle Live readiness. Рекомендуемый старт после закрытия критических blockers - 3-5 качественных статей.

15. Приоритетная дорожная карта до Early Access и Paddle Live

Этап	Задача	Результат	Live blocker
0	Опубликовать и визуально проверить audit/mobile/copy changes	Vercel Ready, mobile QA, \$4.90 displayed	Да: build
1	Refund/adjustment/chargeback lifecycle	Approved full refund/revocation, partial/rejected handling, idempotency	Да
2	Password reset + auth rate limiting	Пользователь восстанавливает доступ; brute-force protection	Да/High
3	Account deletion + personal-data export support workflow	Проверяемая DSR/runbook, identity verification	Да
4	Backups + restore drill	Регулярные dumps и проверенное восстановление	Да
5	Monitoring + global OpenAI budget	Alerts и защита от неожиданных расходов	Да/High
6	Legal owner review	Решены governing law, withdrawal, liability, privacy timing	Да для уверенного Live
7	Paddle Live onboarding	Domain approval, Live product/price/keys/webhook/default link	Да
8	Одна контролируемая Live purchase/refund test	End-to-end validation малыми деньгами	Да перед широким запуском
9	Resources/Guides MVP	3-5 owner-reviewed articles	Нет
10	Branded error/loading/not-found + UX polish	Доверие и завершённость	Нет

Рекомендуемый ближайший шаг

Не смешивать денежную логику с визуальными правками. Следующая отдельная задача Codex - refund / adjustment / chargeback lifecycle. После неё - password reset и auth rate limiting.

16. Контрольные чек-листы

16.1 Перед каждым push

- `git status --short`: понять tracked/untracked изменения.
- `git diff --check` и `git diff --cached --check`.
- Проверить, что `.env`, keys, dumps и screenshots с секретами не staged.
- TypeScript, lint изменённых файлов, релевантные tests.
- Проверить публичные тексты на старые строки и fake claims.
- Собрать логичный commit; не использовать `git add .` без осознанной проверки.
- После push дожидаться Vercel Ready и проверить production вручную.

16.2 Sandbox payment regression

- Guest Pricing показывает \$4.90 и зачёркнутые \$9.90 при Early Access ID.
- Free user CTA открывает Paddle Test Mode checkout.

- Email prefilling соответствует session user.
- Test payment проходит, receipt приходит.
- Webhook переводит User.plan в Pro.
- Settings показывает active subscription.
- Update payment method открывает отдельный action.
- Cancel subscription планирует cancellation at period end; Pro сохраняется.
- Duplicate checkout не создаёт две live Transactions.
- Без Paddle/OpenAI configuration возвращаются понятные безопасные errors.

16.3 Перед Paddle Live

- Paddle account/identity verification завершена.
- Website/domain одобрен.
- Созданы Live Product и Live Price IDs.
- Созданы отдельные Live API key, client token, webhook secret.
- Настроены Live webhook destination и default payment link.
- Production env не содержит смешанных Sandbox/Live значений.
- Refund/chargeback handlers работают и тестированы.
- Support и refund process реально исполняемы.
- Backups и monitoring активны.
- Одна контролируемая реальная покупка и возврат проверены.

17. Архив следующих заданий для Codex

17.1 Критический следующий prompt: refunds / adjustments / chargebacks

Работай только с локальным проектом: F:\creatornivo

Цель: реализовать безопасный Paddle refund/adjustment/chargeback lifecycle перед Live.

Ограничения: не менять цены, Price IDs, checkout ownership, .env, auth, generation limits; не применять миграцию без отдельного подтверждения; не подключаться к production DB в тестах; не делать commit/push/deploy.

Нужно:

- обработать adjustment.created и adjustment.updated;
- сохранять adjustment ID и transaction ID с idempotency;
- различать pending_approval, approved, rejected;
- различать full и partial refund;
- approved full refund: снять Pro или отменить/ограничить access по явно выбранному правилу;
- partial refund: не снимать Pro автоматически без отдельного правила;
- rejected: ничего не менять;
- chargeback/dispute: безопасно снять или приостановить Pro и сохранить reason/status;
- duplicate/out-of-order webhooks не должны повторно менять доступ;
- неизвестный adjustment не должен быть привязан к чужому User;
- добавить audit logging без секретов и prompt content;
- согласовать публичную Refund Policy с фактическим поведением.

Тесты: full approved, partial approved, rejected, pending->approved, chargeback, duplicate event, stale event, unknown transaction, refund after canceled subscription, transaction/subscription ownership.

В отчёте: exact lifecycle, changed files/schema/migration, tests, unresolved policy decisions. После отчёта остановиться.

17.2 Auth hardening

- Forgot/reset password с одноразовым токеном, сроком действия и безопасным email flow.
- Change password для авторизованного пользователя.
- Rate limiting login/register/reset по IP и account identifier.
- Email trim/lowercase, max lengths, password visibility, network error UX.
- Не добавлять OAuth без отдельного решения.
- Email verification - отдельная задача после reset или вместе при готовой mail infrastructure.

17.3 Account deletion и data requests

- Сначала спроектировать verified support workflow без self-service endpoint.
- Определить, какие данные экспортируются: profile, subscriptions, prompts, generations, saved items, timestamps.
- Определить deletion/anonymization с Paddle и финансовыми retention obligations.
- Создать internal runbook, шаблоны писем, identity verification и журнал выполнения.
- После стабилизации решить, нужен ли self-service Delete account.

17.4 Backup / monitoring / spend protection

- Автоматический pg_dump public schema по расписанию, шифрование/доступ, retention и offsite copy.
- Restore drill на отдельной test DB без production overwrite.
- Alerts: failed webhooks, repeated 5xx, checkout failures, auth abuse.
- Не логировать API keys, cookies, full prompts и generated content.
- Global OpenAI daily/monthly budget breaker и owner alert.

17.5 Resources MVP

- Создать /resources и /resources/[slug] без CMS.

- Начать с 3-5 статей из согласованного списка.
- Owner-reviewed content, canonical, sitemap, metadata и honest Article JSON-LD.
- Не использовать fake author, fake stats или AI content без ручной проверки.

18. Журнал решений и спорные вопросы

Решение/вопрос	Зафиксированное состояние
Продавать сейчас или отключить подписки	Не отключать. Sandbox работает; Live только после блокеров.
Нужна ли компания/ФОП в текстах	Не придумывать компанию. Оператор - физическое лицо в Украине. Налоговый статус решается отдельно.
Первые 50 мест	Убрано как недостоверное; founding price доступна ограниченное время.
Early Access price	Сохранить \$4.90; standard \$9.90.
System theme	Следует theme устройства; сохранить с понятным label.
Отмена подписки	Self-service at period end; доступ до конца периода.
Возврат	Отдельный request/process; не равен cancellation.
Немедленная отмена	Administrative operation; не обязательна пользователю.
Receipt email	Prefill session email, но billing email может быть изменён; ownership не по email.
14-day guarantee	Оставлена как owner obligation; требуется операционная и legal проверка.
Governing law Ukraine	Текущая рабочая формулировка, требует юриста.
Resources	Делать после критических financial/auth/ops задач.
Production build	Окончательное доказательство - Vercel Ready и ручной smoke test.
Live launch	После refund lifecycle, account/privacy operations, backup/monitoring, Live Paddle setup.

Как обновлять это досье

После каждого крупного этапа сохранять новую версию с датой и кратким changelog: что закрыто, какие решения изменились, какие Live blockers остались. Старые версии не перезаписывать - они помогают восстановить историю проекта.

Приложение А. Ключевые файлы, затронутые аудитом

- Header/responsive: src/components/layout/header.tsx; footer.tsx; sidebar.tsx; protected/layout.tsx; settings/page.tsx; templates/page.tsx; stats-card.tsx; page-header.tsx.
- Theme: src/components/ui/theme-toggle.tsx; src/config/theme.ts.
- Public copy: hero-section.tsx; explore-templates-section.tsx; how-it-works-section.tsx; showcase-section.tsx; social-proof-section.tsx; featured-templates.ts; onboarding.ts; pricing-display.ts.
- Early Access/Pricing: early-access-banner.tsx; pricing-section.tsx; pro-plan-pricing.tsx; upgrade-button.tsx; src/config/early-access.ts; /api/early-access/status; pricing/page.tsx.
- Legal: src/config/legal/terms-of-service.ts; privacy-policy.ts; refund-policy.ts.
- Generation limits: prisma/schema.prisma; migration generation_reservations; usage-service.ts; generate route; usage route; provider.ts; generate-workspace.tsx; usage-banner.tsx; plan/limits config; generation-limit tests.
- Paddle: checkout route; portal route; webhook route; checkout-service.ts; subscription-service.ts; use-paddle-checkout.ts; subscription-manager.tsx; Paddle tests; checkout intent migration.
- Tests created/updated: legal-copy.test.ts; public-copy.test.ts; responsive-header.test.ts; early-access-status.test.ts; post-checkout-ui.test.ts; paddle-checkout.test.ts; paddle-webhook.test.ts; generation-limits.test.ts.

Приложение В. Что не должно попадать в репозиторий или отчёты

- .env и реальные API keys/client tokens/webhook secrets.
- DATABASE_URL и полные Supabase credentials.
- Auth cookies, session tokens, password hashes и reset tokens.
- Полные Paddle customer/subscription/transaction IDs в публичных screenshots.
- Backup dump-файлы, если репозиторий публичный.
- Prompt/generated content пользователей в logs или monitoring.
- Личный адрес, ИНН и документы владельца без осознанной необходимости.